

2-Hour Lab: Planning & Scoping a Penetration Test

Student Pack & Worksheet

Module: Penetration Testing | Duration: 2 hours | Scenario: ACME Health Systems

Instructions: This document contains the full brief, templates, and worksheets. Submit your completed sections as a single Word document during next weeks Lab.

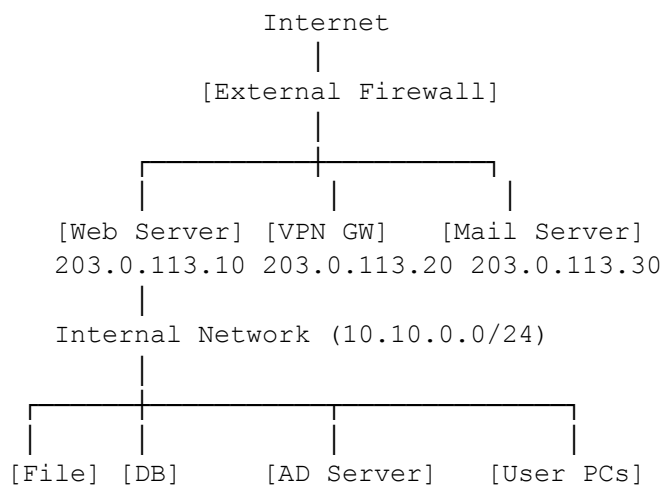
Scenario: ACME Health Systems

ACME Health Systems is a mid-sized medical services provider operating multiple clinics. They process personal and sensitive data (patient demographics, appointment details, and basic clinical notes). ACME requests an external and limited internal penetration test to prepare for an upcoming audit. GDPR applies. No service disruption is permitted Monday–Friday, 08:00–18:00.

Stakeholders

- IT Manager (primary contact): Sarah Whitaker
- Compliance Officer: Daniel Chu
- CEO (signs approvals): Marissa Henley

High-Level Network Diagram



Asset Inventory

Asset	Location	Sensitivity	Notes
Public Web Server	DMZ	Medium	Hosts patient portal
VPN Gateway	DMZ	High	Remote staff access
Mail Server	DMZ	Medium	Staff email
Active Directory	Internal	High	Domain services
File Server	Internal	High	Sensitive documents
Database Server	Internal	High	Patient data
45 User PCs	Internal	Low	Windows 10 endpoints

Lab Timetable & Tasks

0:00–0:10 — Briefing

- Read the scenario and confirm understanding of constraints.

0:10–0:40 — Task 1: Determine the Scope

- Identify in-scope systems, test types, time windows, and assumptions.
- Identify out-of-scope systems/activities with rationale.
- Capture business risks and technical constraints.

0:40–1:10 — Task 2: Draft Rules of Engagement (RoE)

- Define authorisation, contacts, escalation, and change control.
- Specify allowed/prohibited activities and tool restrictions.
- Detail data handling (GDPR), retention, and deletion.

1:10–1:35 — Task 3: Choose & Justify a Methodology

- Select PTES, NIST SP 800-115, OSSTMM, or OWASP WSTG.
- Map phases to ACME's scenario (what will be done in each phase).

1:35–1:55 — Task 4: Produce a Mini Scoping Report

- Write a concise 1–3 page report including all required sections (see template).

1:55–2:00 — Wrap-Up

- Submit your documents and prepare for a short debrief.

Guidance & Examples

Scope Examples

In Scope (examples)

- External: Web server, VPN gateway, mail server, public IP space enumeration.
- Internal (limited): Active Directory and File Server with credentialed checks.

Out of Scope (examples)

- Database stress testing (availability risk).
- Physical security testing and social engineering (not authorised).
- Third-party SaaS applications (not owned by ACME).

Constraints & Risks to Consider

- No disruption Monday–Friday, 08:00–18:00.
- Potential denial-of-service from aggressive scanning — plan safe configurations.
- Legal: Ensure signed authorisation before any testing.
- Data privacy: Limit collection of personal data; securely store and delete within agreed window.
- Change management: Notify ACME before testing high-risk components.

Methodology Primer

PTES (Penetration Testing Execution Standard)

- Phases: Pre-engagement, Intelligence Gathering, Threat Modeling, Vulnerability Analysis, Exploitation, Post-Exploitation, Reporting.
- Suitable for mixed internal/external tests and clear client communication.

NIST SP 800-115

- Emphasises planning, discovery, attack, and reporting with federal-style rigour.
- Good for audit preparation and documentation traceability.

OWASP WSTG (Web Security Testing Guide)

- Deep coverage of web application testing categories.
- Use when the web application (patient portal) is a primary target.

OSSTMM

- Operationally focused with measurable trust metrics across multiple channels.
- Useful for structured scoring and breadth across people, processes, and tech.

Worksheets & Templates

Worksheet A — Scope Definition

Objective	
In Scope (systems/activities)	
Out of Scope (with rationale)	
Test Types (included/excluded)	
Constraints (time, tools, SLAs)	
Time Windows	
Assumptions	
Dependencies	

Worksheet B — Rules of Engagement (RoE)

- Overview & Purpose:
- Authorisation (signed by):
- Points of Contact (primary/secondary):
- Test Schedule & Windows:
- Allowed Activities & Tools:
- Prohibited Activities:
- Communication & Escalation Plan:
- Service Degradation / Incident Handling:
- Logging & Monitoring Expectations:
- Data Handling & GDPR (retention/deletion):
- Deliverables & Reporting:

Worksheet C — Methodology Selection & Justification

- Chosen methodology (PTES / NIST SP 800-115 / OSSTMM / OWASP WSTG):
- Why is this appropriate for ACME's objectives and constraints?
- How will each relevant phase be executed in this engagement?
- What are the expected outputs/deliverables from each phase?

Worksheet D — Mini Scoping Report (1–3 pages)

Executive Summary

Objectives & Scope (in/out)

Rules of Engagement (key points)

Methodology Overview & Rationale

Risks & Constraints

Deliverables & Acceptance Criteria

Approvals Required

Acceptance Criteria & Submission

- Scope is realistic, justified, and clearly distinguishes in/out of scope.
- RoE is complete, professional, and addresses legal/data protection needs.
- Methodology is well-chosen and mapped to the scenario.
- Report is concise, structured, and suitable for a non-technical stakeholder.

Submission: A single Word document, which includes your name and student number on the cover page.

Final Student Checklist

- Scope Definition completed.
- RoE drafted with contacts, schedules, and data handling.
- Methodology chosen and justified.
- Mini Scoping Report drafted (1–3 pages).
- File named correctly and prepared to be submitted to Brightspace during next weeks Lab.

Note:

Make sure that your single Word document submission includes a

1. Cover Page
2. Table of Contents
3. University Declaration and any use of AI